

EXPLOITED VULNERABILITY ADVISORY: CVE-2025-25249

Summary

CVE-2025-25249 in Fortinet Multiple Products is being actively exploited in the wild. A heap-based buffer overflow vulnerability in Fortinet FortiOS 7.6.0 through 7.6.3, FortiOS 7.4.0 through 7.4.8, FortiOS 7.2.0 through 7.2.11, FortiOS 7.0.0 through 7.0.17, FortiOS 6.4 all versions, FortiSwitchManager 7.2.0 through 7.2.6, FortiSwitchManager 7.0.0 through 7.0.5 allows attacker to execute unauthorized code or commands via specially crafted packets CISA requires federal remediation by 2026-09-12; under the CRA, exploitation of an affected product must be reported within 24 hours.

What we know

- **CVE:** CVE-2025-25249
- **Affected:** Fortinet Multiple Products
- **Exploitation:** Actively exploited, added to CISA KEV on 2026-09-09
- **Severity:** CVSS 8.1 High, Network-exploitable, no privileges required, no user interaction (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)
- **Exploitation likelihood (EPSS):** 2%
- **Weakness:** CWE-122, CWE-787

Recommended action

Patch CVE-2025-25249 by 2026-09-12. If you cannot patch immediately, restrict network access to the affected service now (segment it, put it behind a VPN, or take it offline) until you can patch. If you ship an affected product, be ready to file the CRA 24-hour report the moment you find it exploited.

Sources: CISA Known Exploited Vulnerabilities, NIST NVD. Public data; an advisory of active exploitation, not an incident report. Verify applicability to your estate before acting.